〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.23(금)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-23(금), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· 기획서·작업 계획서 제출일에 맞춰 지금까지의 작업을 최종 점검하고 문서를 정리

· 포털 자체에 대한 실전 보안 점검(SOAR 연동 API, 네트워크 경계, 자율 공격 테스트 도구 검증)

■ 조원별 활동 내역

▶ 진혜정 (자동화·상황판)

· 10/19~10/23 전체 작업 세션을 처음부터 재검토해, 기존 트러블슈팅 기록에 빠져 있던 4건(테스트 계정 비밀번호 노출, IP 우회 시도 중 와이파이 장애, SQL 인젝션 종합 테스트 결과, CSRF·보안 헤더 검증)을 찾아 정리

· 기획서(Claude Docs) 3곳 수정: R2 탐지 규칙에 "완곡한 우회 표현" 탐지 반영, 로컬 LLM 폴백 구조의 이점 보강, SECRET_KEY 관련 문구를 실제 결정(교체하지 않고 유지)대로 정정 — 두 문서 PDF 재발행

· `docs/kali-attack-checklist.md`를 실제로 복붙만으로 동작하도록 전면 재작성(CSRF 토큰 자동 처리, 세션 쿠키 파일 방식 통일)

· 포털 로그인 폼 CSRF 보호, 보안 헤더(CSP·X-Frame-Options 등) 적용 여부를 직접 테스트해 정상 동작 확인

· 자율 침투테스트 프레임워크(ARTEX)를 Docker로 설치해 포털(192.168.3.10) 전용으로 범위를 제한한 Task까지 구성했으나, 연결한 LLM(Gemini)이 "권한 여부와 무관하게 공격 수행은 할 수 없다"며 정책적으로 거부해 중단 — 이후 작업은 수동 체크리스트 방식으로 계속 진행하기로 함

▶ 홍주형 (웹·DB 하드닝)

· MySQL DB 포트(3307)를 127.0.0.1 로컬 루프백으로 원천 격리한 상태를 유지하면서도, n8n/SOAR가 악성 IP를 제어할 수 있도록 포털 웹포트(5070)를 통과하는 내부 REST API(Bearer 토큰 인증) 구현

· 팀원(Gilin03)이 구현한 탐지 룰(R5/R6/R8) 전용 자동 차단 API를 PR #5로 병합 — 차단 시간 1~15분 제한, 화이트리스트(포털·팀원 IP) 보호, 루프백 오차단 방지 등 안전장치 포함

· 관련 테스트 58개 전수 실행해 전부 통과 확인(비인가 토큰 차단, IP 차단/해제, 화이트리스트 보호, 허니팟 탐지 유지 등)

▶ 이시헌 (네트워크)

· pfBlockerNG에 국가 단위 차단(중국·러시아·북한, 총 20,007개 IP 대역) 추가 적용, 매일 자동 업데이트로 설정

· n8n·Graylog·Wazuh 등 관리 포트가 pfSense를 아예 거치지 않고 같은 서브넷에서 직접 통신되는 구조적

문제를 발견 — 해당 PC(192.168.3.10)의 Windows 방화벽에서 지정된 IP 외 접근을 막는 스크립트를 작성해 전달(적용은 담당자가 직접)

· 재택 VPN에 2단계 인증(TOTP) 추가를 검토했으나, 현재도 인증서+비밀번호의 사실상 2요소 구조라 추가 작업은 불필요하다고 판단해 마무리

· 자율 침투테스트 프레임워크(ARTEX) 연동을 별도로 시도 — Docker 기동과 Task 설정(범위를 포털 하나로 제한)까지는 성공했으나, Groq·Gemini 등 무료 LLM 경로가 전부 구조적 호환성 문제(요청 토큰 한도 초과, 모델 단종, 응답 서명 호환 오류 등)로 막혀 LLM 연결에는 실패 — 유료 Anthropic API가 아니면 어렵다는 결론으로 보류

▶ 김태빈 (탐지)

· .77 테스트 PC에서 404 요청 35건을 발생시켜 Graylog R8 Event 생성과 n8n production 워크플로 수신을 확인

· false gate(response_mode=dry-run, live_enabled=false, ip_block_enabled=false) 상태에서 R8 자동 차단 흐름을 검증 — ip_block_enabled=false가 R8 gate까지 정상 전달돼 실제 Block API는 호출되지 않는 것을 확인

· false gate 상태에서도 Incident Ticket 생성과 Discord 알림은 정상 유지되는 것을 확인

· Incident Ticket의 alert 중복 방지, grouping key, count, first_seen/last_seen 동작을 읽기 전용으로 점검

· true gate(실제 IP 차단→403→해제) 및 TEST-NET API 작업은 오늘 확인 가능한 실행 근거가 부족해 완료로 기록하지 않고 내일로 이월

■ 조원별 의견 및 제안 사항

· 홍주형: DB 포트는 외부에 열지 않으면서도 SOAR 자동화가 가능하도록 "웹포트를 통과하는 내부 API" 구조로 풀었다는 점을 강조. 테스트 커버리지(58개)를 제출 자료 근거로 활용 가능

· 이시헌: 네트워크 경계(pfSense) 밖에서 벌어지는 호스트 간 직접 통신은 방화벽 규칙만으로 못 막는다는 걸 이번에 재확인, 앞으로도 호스트별 방화벽 점검이 병행되어야 함

· 진혜정: 이시헌 님과 각자 독립적으로 ARTEX(자율 공격 도구) 도입을 시도했는데 둘 다 상용 LLM의 정책적 거부에 막혀, "자율 공격 자동화"는 이번 공방전 범위에서는 포기하고 수동 테스트로 가는 게 맞다는 결론에 의견 일치

■ 회의 결과 및 결정 사항

1. 기획서·작업 계획서는 오늘자 기준 최신 상태로 제출 완료(제출: 진혜정 1인)
2. SOAR 자동 대응은 포털 내부 REST API(웹포트 경유) 방식으로 확정, DB 포트 외부 개방은 계속 금지
3. 관리 포트(n8n·Graylog·Wazuh 등) 노출은 pfSense가 아니라 각 호스트의 로컬 방화벽으로 막기로 역할 재정리
4. 자율 공격 에이전트(ARTEX) 도입은 보류, `docs/kali-attack-checklist.md` 기반 수동 테스트로 계속 진행

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- 포털의 SOAR 연동 API와 탐지 룰 자동 차단(R5/R6/R8)이 테스트 통과 상태로 구현 완료
- 네트워크 경계 보강(GeoIP 차단, 관리 포트 노출 대응) 진행 중, 일부는 담당자 수동 적용 대기
- 자체 보안 점검(CSRF, 보안 헤더)에서 양호한 결과 확인

· 어려운 점

1. 자율 공격 테스트 도구(ARTEX)를 두 명이 각각 시도했으나 무료 LLM 경로가 전부 막혀 실질적인 진전이 없었음 — 시간 소모 대비 성과가 낮아 보류
2. 프롬프트 인젝션 완화 표현 우회, 세션 서명 키 강도 등 일부 트러블슈팅 항목은 아직 재검증 전
3. 이시헌 님이 전달한 Windows 방화벽 스크립트 등 일부 조치는 담당자의 직접 적용이 남아 있음

■ 향후 활동 계획 및 역할 분담

· 수동 공격 체크리스트(`kali-attack-checklist.md`)로 IDOR, 간접 프롬프트 인젝션, SSRF, 세션 쿠키 변조 테스트를 이어서 진행(진혜정)

· 관리 포트 노출 방지 스크립트 실제 적용 및 재검증(해당 호스트 담당자)

· 세션 서명 키 강도 재검증을 별도 보안 테스트 도구로 재시도

· 리허설(11/5)·본발표(11/6) 전까지 트러블슈팅 미해결 항목 순차 정리

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/23) 페이지

- 진혜정 - 10/23 작업 / 2026-10-23 NEXUS WORK 전체 작업 회고록(홍주형) / 10/23 조별과제 작업 현황(이시헌) / 2026-10-23 작업 기록(김태빈, 개인 워크스페이스)

· 트러블슈팅 모음 페이지(10/19~10/23 전체 이력 정리)